UNIVERSITI KUALA LUMPUR

MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY

L01-B04

PENETRATION TESTING REPORT :

PAWN TILL DAWN

BIL	NAME	MATRIX NUMBER
1	MUHAMMAD SYAKIRIN BIN MOHD HANIF	52215125427

INSTRUCTOR: MADAM NOR ADANI KAMAL MOHAMAD NASIR

1. Executive Summary

This report explain the details of penetration testing conducted to attack the target machine **PwnDrive System (IP:10.150.150.11)** and use **Windows Server 2008 R2** as os. The primary objectives is to identify the machine system vulnerabilities and conduct an hacking which consists of 6 stages. The stages are **Reconnaissance**, **Scanning**, **Gaining access**, **Escalate privileges**, **Maintaining access** and **Clear tracks**. The assessment has successfully compromised the machine by exploiting the flaws in the server configurations and backdoor.

2. Hacking Stages

- Reconnaissance

Initial steps are taken to ensure the target is up and approachable via PwnTillDawn VPN network. This stages highlight the ping test performed on the target IP (**10.150.150.11**).

Result : The system provides a stable response with average latency of 0.16s

```
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-30 10:48 EDT
Nmap scan report for 10.150.150.11
Host is up (0.16s latency).
Nmap scan report for 10.150.150.12
Host is up (0.16s latency).
Nmap scan report for 10.150.150.13
Host is up (0.16s latency).
Nmap scan report for 10.150.150.15
Host is up (0.16s latency).
Nmap scan report for 10.150.150.17
Host is up (0.16s latency).
Nmap scan report for 10.150.150.18
Host is up (0.16s latency).
Nmap scan report for 10.150.150.21
Host is up (0.16s latency).
Nmap scan report for 10.150.150.27
Host is up (0.16s latency).
Nmap scan report for 10.150.150.38
Host is up (0.16s latency).
Nmap scan report for 10.150.150.48
Host is up (0.16s latency).
Nmap scan report for 10.150.150.55
Host is up (0.16s latency).
Nmap scan report for 10.150.150.56
Host is up (0.16s latency).
```

Figure 1 Nmap -sn Result

Initial testing was performed by using the ping command to test the network connectivity between the attacker machine (**Kali Linux**) and the machine (**10.150.150.11**). The results showed a stable connectivity which indicate that port scanning are allowed.

```
┌──(kali㉿kali)-[~]
└─$ ping -c 4 10.150.150.11
PING 10.150.150.11 (10.150.150.11) 56(84) bytes of data.
64 bytes from 10.150.150.11: icmp_seq=1 ttl=127 time=162 ms
64 bytes from 10.150.150.11: icmp_seq=2 ttl=127 time=162 ms
64 bytes from 10.150.150.11: icmp_seq=3 ttl=127 time=163 ms
64 bytes from 10.150.150.11: icmp_seq=4 ttl=127 time=162 ms

--- 10.150.150.11 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3009ms
rtt min/avg/max/mdev = 161.585/161.990/162.948/0.555 ms
```

Figure 2 Ping -c Result

- Scanning

This stages highlights the effort to reveal the open port and services which are running in the systems. The tool is **Nmap v7.95** and command is **sudo nmap -sV -sC -A 10.150.150.11**.

Table 1 Open Port Scanning and Services

Port	Status	Services	Information
21	open	FTP	XLight ftpd 3.9
80	Open	HTTP	Apache httpd 2.4.46 (PwnDrive Web)
445	Open	SMB	Windows Server 2008 R2 (SMB Signing Disabled)
1433	Open	MS-SQL	Microsoft SQL Server 2012
3389	open	RDP	Remote Desktop Protocol

Below shows the result of sudo nmap command onto this IP (**10.150.150.11**).

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC 10.150.150.11
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-30 11:10 EDT
Nmap scan report for 10.150.150.11
Host is up (0.16s latency).
Not shown: 985 closed tcp ports (reset)
PORT      STATE SERVICE       VERSION
21/tcp    open  ftp           Xlight ftpd 3.9
80/tcp    open  http          Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-title: PwnDrive - Your Personal Online Storage
|_http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
443/tcp   open  ssl/http      Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
| tls-alpn:
|_  http/1.1
|_http-title: PwnDrive - Your Personal Online Storage
| ssl-cert: Subject: commonName=localhost
| Not valid before: 2009-11-10T23:48:47
|_Not valid after:  2019-11-08T23:48:47
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
|_ssl-date: TLS randomness does not represent time
445/tcp   open  microsoft-ds  Windows Server 2008 R2 Enterprise 7601 Service Pack 1 microsoft-ds
1433/tcp  open  ms-sql-s      Microsoft SQL Server 2012 11.00.2100.00; RTM
| ms-sql-ntlm-info:
|   10.150.150.11:1433:
|     Target_Name: PWNDRIVE
|     NetBIOS_Domain_Name: PWNDRIVE
|     NetBIOS_Computer_Name: PWNDRIVE
|     DNS_Domain_Name: PwnDrive
|     DNS_Computer_Name: PwnDrive
|_    Product_Version: 6.1.7601
| ms-sql-info:
|   10.150.150.11:1433:
|     Version:
|       name: Microsoft SQL Server 2012 RTM
|       number: 11.00.2100.00
|       Product: Microsoft SQL Server 2012
|       Service pack level: RTM
|       Post-SP patches applied: false
|_    TCP port: 1433
|_ssl-date: 2026-03-30T15:26:06+00:00; +13m58s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
```

Figure 3 Sudo Nmap -sV -sC Result

```
3306/tcp  open  mysql          MariaDB 5.5.5-10.4.14
| mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.4.14-MariaDB
|   Thread ID: 294
|   Capabilities flags: 63486
|   Some Capabilities: Support41Auth, SupportsTransactions, IgnoreSpaceBeforeParenthesis, Speaks41ProtocolOld, Igno
reSigpipes, DontAllowDatabaseTableColumn, ODBCClient, ConnectWithDatabase, SupportsCompression, FoundRows, Interact
iveClient, SupportsLoadDataLocal, LongColumnFlag, Speaks41ProtocolNew, SupportsAuthPlugins, SupportsMultipleStatmen
ts, SupportsMultipleResults
|   Status: Autocommit
|   Salt: JJs%[}#3uvpNv'ZpFJ#l
|_  Auth Plugin Name: mysql_native_password
3389/tcp  open  ms-wbt-server?
| ssl-cert: Subject: commonName=PwnDrive
| Not valid before: 2026-03-29T15:20:26
|_Not valid after:  2026-09-28T15:20:26
| rdp-ntlm-info:
|   Target_Name: PWNDRIVE
|   NetBIOS_Domain_Name: PWNDRIVE
|   NetBIOS_Computer_Name: PWNDRIVE
|   DNS_Domain_Name: PwnDrive
|   DNS_Computer_Name: PwnDrive
|   Product_Version: 6.1.7601
|_  System_Time: 2026-03-30T15:34:37+00:00
|_ssl-date: 2026-03-30T15:34:46+00:00; +13m58s from scanner time.
49152/tcp open  msrpc          Microsoft Windows RPC
49153/tcp open  msrpc          Microsoft Windows RPC
49154/tcp open  msrpc          Microsoft Windows RPC
49155/tcp open  msrpc          Microsoft Windows RPC
49156/tcp open  msrpc          Microsoft Windows RPC
49157/tcp open  msrpc          Microsoft Windows RPC
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:mi
crosoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 2 hops
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
```

Figure 4 Sudo Nmap -sV -sC Result

```
Host script results:
| smb-os-discovery:
|   OS: Windows Server 2008 R2 Enterprise 7601 Service Pack 1 (Windows Server 2008 R2 Enterprise 6.1)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::sp1
|   Computer name: PwnDrive
|   NetBIOS computer name: PWNDRIVE\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-03-30T08:34:36-07:00
| smb2-time:
|   date: 2026-03-30T15:34:37
|_  start_date: 2024-03-21T12:57:13
| smb2-security-mode:
|   2:1:0:
|_    Message signing enabled but not required
|_clock-skew: mean: 1h13m58s, deviation: 2h38m45s, median: 13m57s
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: PWNDRIVE, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:89:87:cb (VMware)

TRACEROUTE (using port 1723/tcp)
HOP RTT       ADDRESS
1   163.17 ms 10.66.66.1
2   163.29 ms 10.150.150.11

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 110.54 seconds
```

Figure 5 Sudo Nmap -sV -sC Result

- Gaining Access

Based on the scan results, a potential vulnerability was found in the PwnDrive web application. By using the **Nikto Tool**, it has successfully found a clue of /admin/ directory which has a **Directory Indexing** problem.

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://10.150.150.11
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.150.150.11
+ Target Hostname:    10.150.150.11
+ Target Port:        80
+ Start Time:         2026-03-30 22:07:28 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
+ /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Coo
kies
+ /: Retrieved x-powered-by header: PHP/7.4.9.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web
/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the sit
e in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilitie
s/missing-content-type-header/
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file name
s. The following alternatives for 'index' were found: HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FO
UND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, H
TTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.h
tml.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_N
OT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.v
ar. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ PHP/7.4.9 appears to be outdated (current is at least 8.1.5), PHP 7.4.28 for the 7.4 branch.
+ Apache/2.4.46 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x br
anch.
+ OpenSSL/1.1.1g appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch a
nd will be supported until Nov 11 2023.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community
/attacks/Cross_Site_Tracing
+ /config.php: PHP Config file may contain database IDs and passwords.
+ /Admin/: Directory indexing found.
+ /admin/: Directory indexing found.
+ /admin/: This might be interesting.
+ /css/: Directory indexing found.
+ /css/: This might be interesting.
+ /img/: Directory indexing found.
+ /img/: This might be interesting.
```

Figure 6 Nikto -h Scan Result

After finding the clue of /admin/ directory, the /admin/ path shows a unique ways to enter the administration without the need for authentication. Later, I created a **new account** named “Kirin” while figure 7 shows the ui of the /admin directory

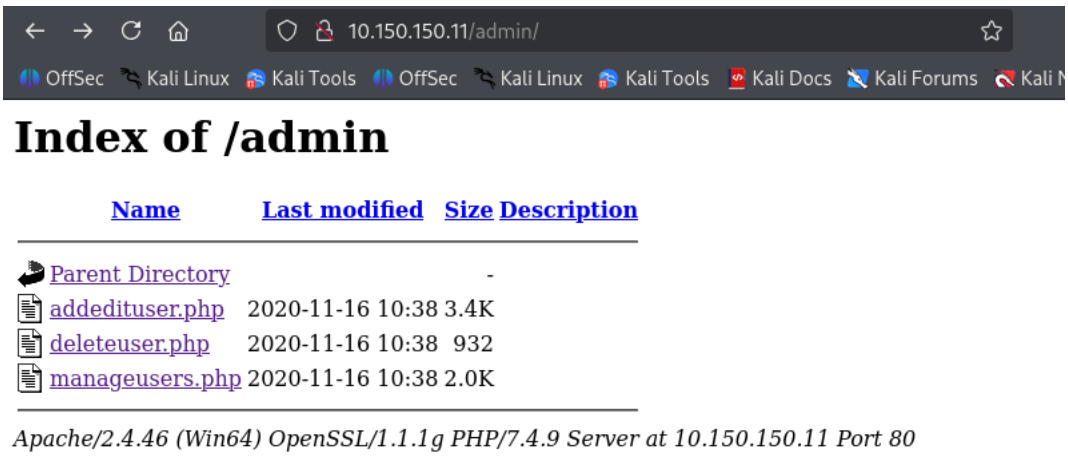

Figure 7 UI of /admin/ path

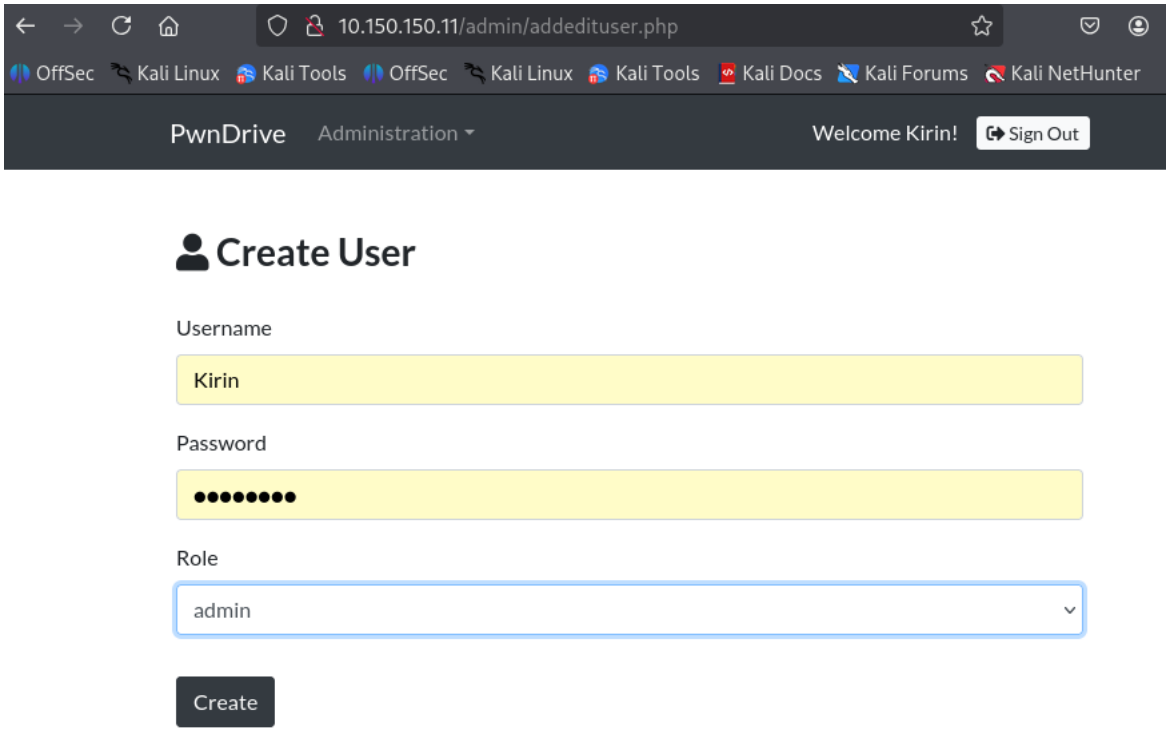

Figure 8 Creating New Account

After logging in, I was allowed to add any files including jpeg and txt files. Then, this function can be abuse by uploading the problematic files. Thus, I uploaded the shell.php file containing the PHP Web Shell code as figure below.

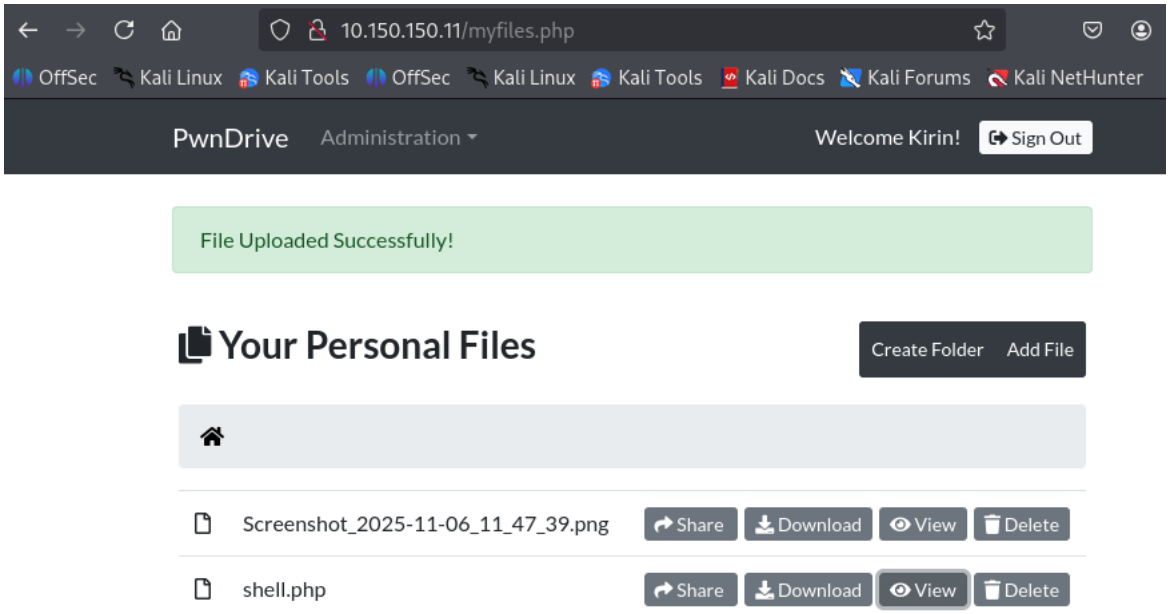

Figure 9 Uploading shell.php Files

- Escalate Privileges

Although access is initiated via a web application, due to the poor server configurations, access continues to be obtained with admin authority level.

This is done my directing my path the the uploaded harmful files in the website and gaining the authority\system.

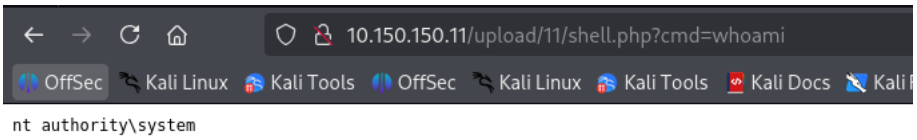

Figure 9 Compromised Root Level

Command : http://10.150.150.11/upload/11/shell.php

Flag Discovery : With this authority, I was be able to read the flag file destination on the admin desktop. By using **cmd=dir C:\Users\Administrator….** I can manuever into the admin desktop. Figure below show how I find the flag location.

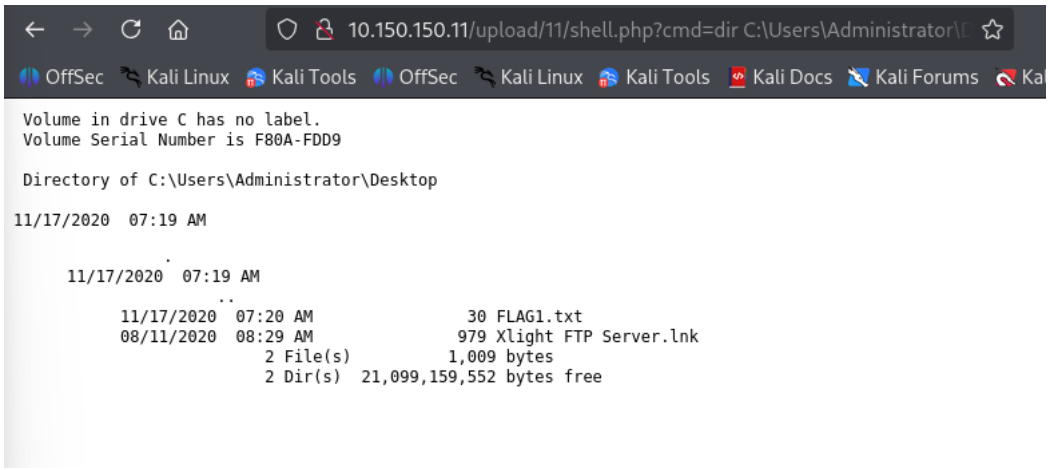

Figure 9 Flag Location

- Maintaining Access

To ensure access is not lose while exploiting the system, several “backdoor” measures have been taken. The file shell.php is left in the /upload/11/ folder as a quick entry point.

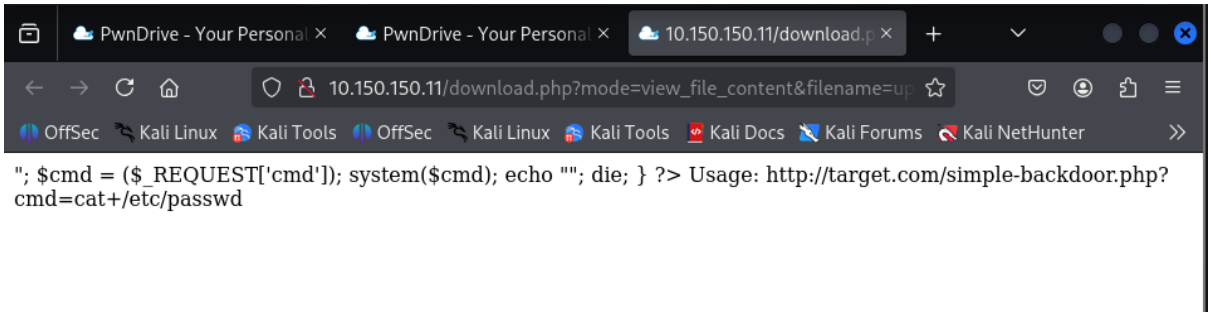

Figure 10 shell.php files Stored in Downloads

The created new account remains active in the web application database to allow for legitimate re-logins.

- Clear Logs

The final steps is to remove all trackable evidence to avoid detection by monitoring systems.

Delete the shell.php file in the website

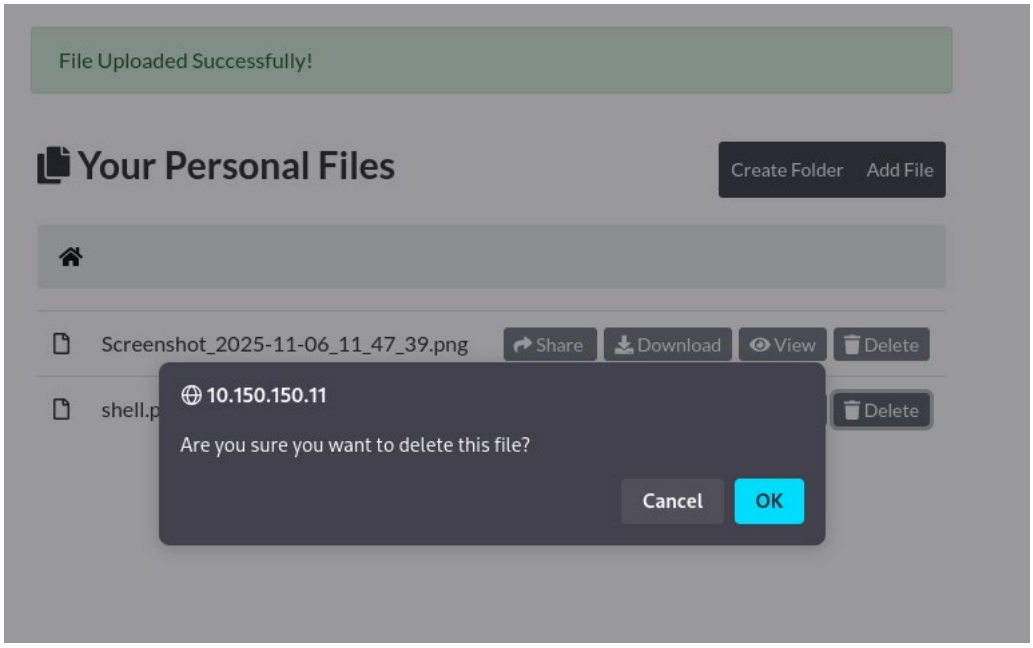

Figure 11 Deleting shell.php Executable Files

Next, deleting the user “Kirin” from the website is important to delete the evidence for this attacks.

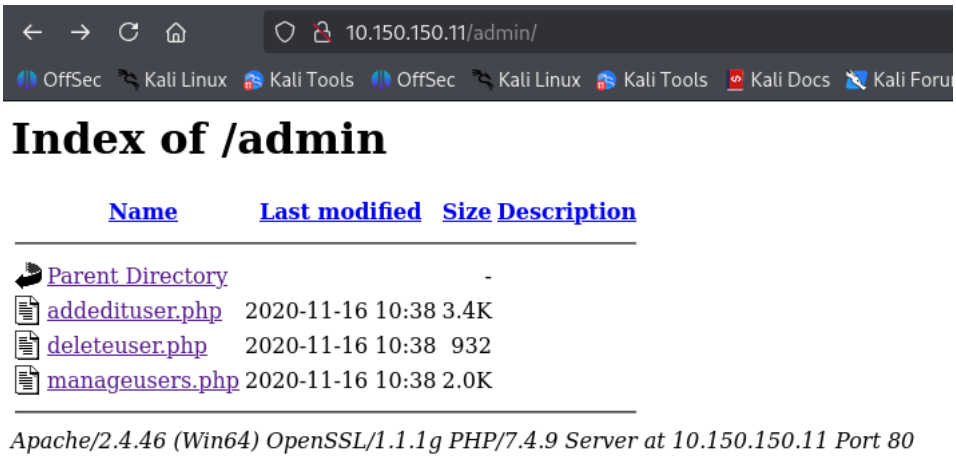

Figure 12 Deleting User Account

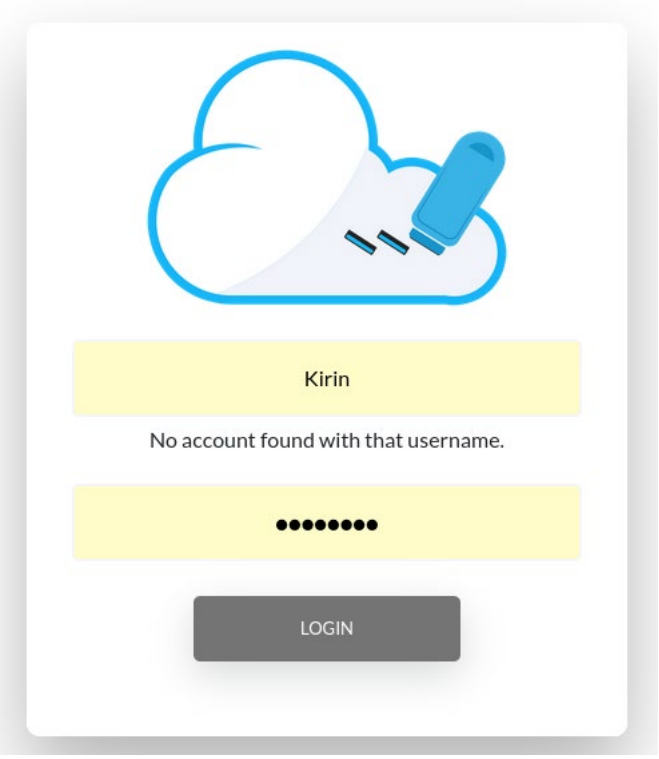

Figure 12 Succession of Deletion

Appendices

A: Main Flag Achieved

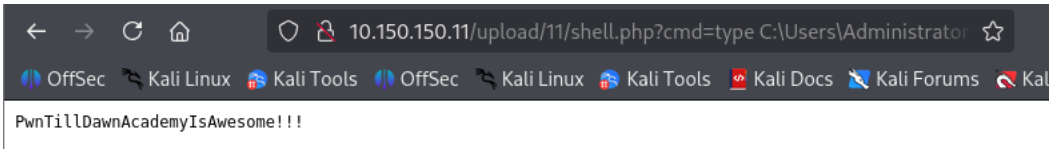

Figure A.1 Flag Obtained

B: Creating CP Shell Backdoor Executable File

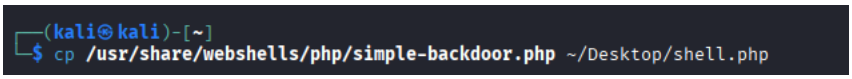

Figure A.2 shell.php Created File

C: Exploiting FTP

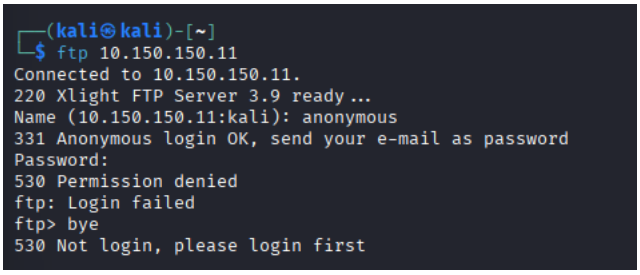

Figure A.3 FTP Command Result